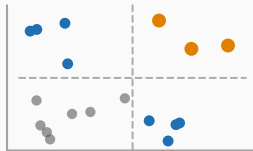


Risque opérationnel et résilience

Chapitre 12 : La maîtrise du risque d'externalisation



Avant de commencer

Les risques posés par les prestataires

Construire un programme de gestion du risque prestataire

Surveillance continue et plan de continuité

Synthèse

Avant de commencer

Pourquoi ce chapitre ?

Après la criminalité financière, ce chapitre s'attaque à un risque plus discret mais tout aussi consommateur de contrôle : celui de confier une partie de son activité à un prestataire externe. Ce chapitre reprend la lettre de supervision SR 13-19 de la Réserve fédérale américaine, un texte de référence sur la gestion du risque d'externalisation.

Les risques posés par les prestataires

Cinq catégories de risque

Le risque de **conformité** survient lorsque les services d'un prestataire enfreignent les lois ou règlements applicables. Le risque de **concentration** naît lorsque des services externalisés sont fournis par un nombre limité de prestataires ou concentrés sur une zone géographique restreinte. Le risque **réputationnel** provient d'actions ou de contre-performances du prestataire qui ternissent l'image de l'établissement. Le risque **pays** apparaît dès lors que le prestataire est situé à l'étranger. Le risque **opérationnel**, enfin, naît de processus ou systèmes internes défectueux chez le prestataire, ou d'événements externes et d'erreurs humaines.

Externaliser ne transfère pas la responsabilité

Recourir à un prestataire ne dispense en rien le conseil d'administration et la direction générale de leur responsabilité de s'assurer que l'activité externalisée est conduite de manière saine et conforme à la réglementation. Cette responsabilité, contrairement à l'activité elle-même, ne se sous-traite pas.

Construire un programme de gestion du risque prestataire

Les six piliers du dispositif

Un programme efficace comprend : l'**évaluation des risques** de l'activité envisagée; la **diligence raisonnable** et la sélection du prestataire; les **clauses contractuelles**; la revue des **incitations de rémunération** intégrées au contrat; la **surveillance continue** du prestataire; et la **planification de la continuité d'activité** en cas de défaillance du prestataire.

Une profondeur proportionnée au risque

L'ampleur du dispositif doit être proportionnée à la criticité, à la complexité et au nombre d'activités externalisées. Un établissement de petite taille recourant à quelques prestataires réputés pour des fonctions critiques peut se contenter d'un dispositif plus simple; un établissement s'appuyant sur des centaines de prestataires pour des activités à risque matériel devra mobiliser un dispositif nettement plus riche.

Trois axes d'examen

Avant d'engager un prestataire, l'établissement doit examiner sa réputation et sa stratégie d'affaires, sa situation financière, et ses contrôles internes et opérationnels — y compris, le cas échéant, sa propre diligence sur ses sous-traitants (le « risque de quatrième partie »).

Ce qu'inclut la revue financière

La revue financière porte sur les états financiers récents, la solidité du capital, la liquidité, les résultats d'exploitation, la pérennité de l'activité (ancienneté, croissance de part de marché), l'adéquation de la couverture d'assurance, et l'engagement du prestataire — en ressources financières et humaines — à honorer le contrat sur toute sa durée.

Ce qu'un contrat bien conçu doit prévoir

Un contrat solide définit le **périmètre** des responsabilités de chaque partie, les modalités de **coût et de rémunération**, un **droit d'audit**, des **normes de performance mesurables**, des exigences de **confidentialité et de sécurité de l'information**, les conditions de **propriété et de licence** des données et logiciels, une clause d'**indemnisation**, les conditions de **défait et de résiliation**, un mécanisme de **résolution des différends**, des exigences d'**assurance**, et un plan de **continuité d'activité** du prestataire lui-même.

Le cas particulier des données non publiques

Si le prestataire traite des informations personnelles non publiques (NPPI) des clients, il doit se conformer aux lois sur la vie privée et notifier toute violation impliquant ces données. La sécurité, la conservation et l'accès à ces données doivent être explicitement traités dans le contrat — la responsabilité de leur divulgation incombant conjointement à l'établissement et à son prestataire.

Les prestataires étrangers ajoutent une couche de complexité

Un contrat avec un prestataire situé à l'étranger devrait désigner explicitement la juridiction applicable en cas de litige, afin d'éviter qu'un tribunal étranger n'interprète le contrat selon un droit local potentiellement moins protecteur. Les banques américaines restent en outre tenues de respecter l'ensemble de leur réglementation nationale, même lorsque le prestataire opère depuis l'étranger.

Surveillance continue et plan de continuité

Des indicateurs de performance, une escalade graduée

L'établissement doit fixer des indicateurs de performance mesurables et adapter la fréquence de sa surveillance au niveau de risque du prestataire : plus fréquente et plus stricte pour les prestataires à risque élevé ou montrant des signes de difficulté financière ou de non-conformité, allégée pour les prestataires à faible risque. Des déclencheurs d'escalade doivent permettre de remonter rapidement tout signal de dégradation vers la direction.

Se préparer à la défaillance du prestataire

Le plan de continuité doit prévoir la sauvegarde des informations, l'articulation avec le propre plan de reprise après sinistre de l'établissement, des tests périodiques, et une stratégie de sortie incluant un vivier de prestataires alternatifs comparables au cas où le prestataire retenu ne pourrait plus assurer le service.

Un contrôle interne toujours nécessaire

Pour les relations les plus significatives, l'établissement doit évaluer la qualité du dispositif de contrôle du prestataire — par exemple via un rapport d'audit type SOC 2 — et intégrer les incidents de sécurité survenus chez le prestataire à sa propre surveillance. Aucun contrat, aussi bien rédigé soit-il, ne remplace une vérification active et continue.

Synthèse

Synthèse du chapitre

L'externalisation ne transfère jamais la responsabilité ultime d'une activité — seulement son exécution quotidienne. Gérer ce risque suppose un dispositif complet : évaluer le risque en amont, exercer une diligence raisonnable rigoureuse sur le prestataire pressenti, négocier un contrat qui couvre explicitement la performance, la sécurité, l'audit et la sortie, puis surveiller la relation dans la durée avec une intensité proportionnée au risque, tout en préparant activement le scénario où le prestataire ne pourrait plus honorer ses engagements.